

Privacy Preserving Policy Framework: User-Aware and User-Driven

Sanchari Das¹, Jayati Dev¹, and L. Jean Camp¹

Indiana University Bloomington, Bloomington IN 47408, USA

{sancdas, jdev, ljcamp}@iu.edu

Abstract. Privacy policies outline and structure data collection and access management for online services or websites. These policies are often too long, complex, and convoluted for an average internet user to understand which is a factor in why these policies are ignored. Prior work has mostly focused on improving the accessibility of these privacy policies. Here we focus on making the policies more resemble the negotiation they are supposed to represent by providing flexibility to people. An example is a website which offers various services such as photo, video, or location sharing, where the people are required to either accept the privacy policy to access all the services provided by the website or be prevented from using any of the services. Our goal is to map privacy policy statements to the distinct services offered by a website allowing people to agree for only the services they wish to use. By not agreeing to a policy statement, the access would be denied only on the corresponding service instead of following the all or none mechanism. Additionally, this would also prevent the website from collecting data from people for a particular service which they have no current or future desire to use, in accordance with the principle of data collection minimization.

We propose a privacy policy framework to promote transparency for consumers, credibility and trust building for the organization, and clarity in data storage for the developers. Our modular service-policy map for developers allow them to easily associate new features to the corresponding privacy policy section. Modularizing enables developers, organizations, customers, and other stakeholders to understand how specific services correspond with individual data compilations. With the current ongoing debate of data access strategies in social media platforms, our initial framework is based on Facebooks privacy policy because of the diversity in services that the platform offers. However, the framework can be widely applied across various social media, business, and health care policies. Finally, through pilot interviews with existing consumers, we report on the initial validity testing of our proposed framework. Our early findings are promising in terms of meeting the goals of promoting privacy awareness and increasing trust in organizations' privacy policies.

1 INTRODUCTION

Privacy policies often are lengthy documents which are rarely read by customers [13, 17], both in the case of websites and mobile applications. Reasons for lack of attention to these documents are manifold; the language is complex, and includes legal jargons. Policies are often arduously long, averaging over 2500 words [28], with very little incentive to read them. Once they are read the clause noting that immediate or frequent changes may occur further discourages investment in reading such policies in the future. Previous research show that only 41% of people have ever read a single privacy policy, and most are not well informed about the extent of data handling practices by online services [2]. Such works are based on data reported by participants in experiments, with the normal caveats applying. Even if these policies are read, they are vague about the nature and extent of the data being used and stored [32].

Additionally, as researchers note, the choice of accepting a privacy policy is always binary [9, 33]. This means that people are forced to either agree to the privacy policy *entirely* or forego the possibility of using the particular web or mobile application associated with the policy. Recent changes in the Android and iOS permission model have enabled people to choose not to grant access to particular data by an app, yet still use them. However, policy documents remain vague about opaque background app data collection [24]. Additionally, once people accept a policy during the registration or installation process, they can seldom control any of the subsequent policy updates, and do not have a choice in rejecting all or parts of the policy later on. This is especially important for all services that collect sensitive information, such insurance companies, health care providers, governmental entities, and social media platforms [7].

While considering social media platforms; Facebook is among the leading social media websites across the globe. Facebook claims to have 2.41 billion monthly active users as of the second quarter of 2019 [1]. It has an extensive privacy policy with details about data collection and access, including a separate policy for browser cookies. Facebook also has two features specific to privacy settings; **Privacy Check** which enables people to stay updated and lock-down their privacy preferences; **Privacy Basics** which educates its consumers on how they can control their privacy. These are means of privacy control beyond Facebook's privacy policy, which it refers to as the *Data Policy* interchangeably, which is quite detailed and extensive despite the recent privacy controversies involving Facebook [41]. However, statistics reveal that much like the others, Facebook's Data Policy is seldom read [14]. Thus, our goal is to develop a modular privacy policy framework, described in section 3.1, to provide more detailed and transparent data storage and access.

Briefly, the contributions of this work to the community are as follows:

- Describe the development of a service-specific policy model that would ensure standardization of privacy policies in general.
- Offer a proposal for a specific modular policy framework. The goal of the framework is to increase acceptability by consumers, while simplifying compliance by developers and service providers [36, 39]. The range of global privacy regulations may make such a framework valuable for developers concerned about GDPR [23, 27].
- Offer a pilot study intended to assess acceptability and usefulness of this modular policy. This is to ensure users are an integral part of the framework development process while measuring any changes in individual trust in online services. Trust is an important component of these questions, and a successful framework would enable increased trust in online organizations.

2 RELATED WORK

Facebook's privacy policy is ranked second in terms of terminology and clarity [37]. Even then, it requires '*college-level reading skills*' [33] for an average user to read through each of these documents to comprehend about the data access legalities. As prior literature establishes, privacy policy reveal important information about what user data is collected and how it is stored, but it is never read by people at large. Additionally, all of these privacy or a data access policies always has a binary option for the user, who will not be able to use any of the services if they do not agree to the entire policy [9], leaving little scope for choice. Now-a-days, the permission setting does provide some options for the people, however, from the legal perspective, it's often murky creating little to no changes in these policies due to permission access choices [30].

On the positive side, there have been several attempts to improve policy readability and usability. One of the earliest attempts was the P3P (Platform for Privacy Preferences) project that tested the privacy policy of a website or online service that a user visits to check whether it conforms with the privacy preferences of people which fits into the broader definition of security in personalization [10]. Ever since its release, P3P has been an important new interface

that adapts to generic privacy policies and provide an extra layer of privacy beyond the website certificates. There have a lot of additional studies around P3P such as an identity management system developed by Berthold [3] and the Privacy Bird software developed at AT&T by Cranor et al. [12] to automate privacy policy statements according to P3P mechanism. A variation of the P3P have been proposed by Teltzrow and Kobsa who determine two alternatives to user-adaptive interfaces: First, allow user to access website using personal identification if P3P protocol is satisfied. Second, allow anonymous user exploration if P3P is not satisfied by using "interface attributes" instead of raw and unencrypted personal data [40]. Irrespective of such tools and guidance available in the academic world, such components are seldom implemented in organizations at large.

An interesting user-adaptive software has also been developed for mobile application security and privacy by Mandal et al. which uses a graphical user interface to show the user privacy settings and display advisory notices in the interface to guide privacy decisions [26]. Due to the development of thousands of mobile applications, a lot of research in this dimension are also taking place, especially to build recommendations for permissions and security-aware personalization for these applications [44]. There are two other new interface approach that have been made towards better implementation of privacy in user-adaptive systems by using personalization. In a *Privacy Controller Approach* towards protection in online services, a privacy policy based on user's preferences is developed at first, to be inline with the legislative and citizen rights. Then, the privacy policy of the online web service is studied to find its compliance with existing laws. The results of the latter helps website establish its trust-worthiness because they have been found to be legally complaint. After the compliance establishment, the user has a choice of either going through the website or not, independent of whether these privacy preferences match [42]. However, this study has only been done for e-commerce platforms and has a huge scope of application on other portals such as, health and insurance.

There has been more detailed work on mobile application permissions, which show the different components of the cellular device it needs to access to function, and which can be controlled later through the device's settings. This is a very transparent way to communicate access control intentions to the user [16]. Privacy nudges and indicators have also been helpful in encouraging privacy preserving behaviour amongst people [8]. Studies also show that people care about their data privacy and given a choice and knowledge about data access policies, would like to moderate them [15] and designing these policies to gain user trust is more beneficial for the organizations in the long run [6].

3 POLICY MODELS

Privacy policies address an organization's data handling procedures. However, previous literature have elaborately explained why they fall short of alleviating people's privacy concerns. On a closer analysis, it is evident that this might be partially due to information overload, since there is no standardization in how privacy policies are written. It is also true for organizations, who might not sufficiently or transparently address all data retention policies due to the unstructured nature of privacy policies in general [22].

The goal of this paper is to provide a template that intends to make privacy policies more transparent for users, so that they can find *exactly* what they are looking for. For example, if a user wants to view all kinds of data used by a specific service, they might directly scroll to the part of the privacy policy that addresses it. Giving this control to people is beneficial for an organization in two ways; a clear, more transparent policy would encourage people to have greater trust in the organization, furthermore, the very structured nature of modular policies would aid developers to update them easily, with new clauses, data requirements, or features.

3.1 Modular Privacy Policy

In this paper, we propose a modular privacy policy framework, divided into sections according to the respective services offered by Facebook. It allows people to agree to specific sections of privacy policy for specific services. Since such policies is required to state the data collected with respect to people by various services, we can create separate modules for each service detailing the kind of data it collects. This concept enables users to clearly see what kind of data is collected by each of the services that they choose and empower them to decline to use the service by opting out of privacy policy module corresponding to that service.

We attempt to explore the following research questions in our work:

- Do modular privacy policies improve clarity and usability?
- Does modularizing a privacy policy enhance user acceptability and increase probability of them actually reading it?

- *Does introducing modular policies enhance trust in the organization? We know that people may or may not decide to use a website based on privacy but will a better privacy policy design encourage more people to use an online service in particular?*
- *Does modularity expose gaps in privacy policy which were previously obscured?*
- *Will people choose to forego certain services for better privacy?*
- *Are modular privacy statements easier to read and understand?*

In the current model that we develop, there are two design principles that we consider based on Norman's '*Design of Everyday Things*' [29]. Using the established concept as a foundation the first step we choose to develop a conceptual model, in this case for selective privacy policy statements. Secondly, we aim to improve clarity and visibility in the policy model. One criticism of the most significant previous work in this space, Platform for Privacy Preferences [11] is that it lacked hierarchies and that the same policies could result in very different P3P descriptions [38,43]. By focusing on individual services, rather than entire websites, we aim to avoid this inconsistency. Further, by recognizing that websites are increasingly bundles of services the modular approach may be more useful for individuals.

3.2 Facebook Privacy Settings vs Modular Privacy Model

One important distinction to be made is the difference between Facebook privacy settings and our modular privacy model. Facebook privacy settings allow its users to hide information from other people on Facebook and the public, but Facebook has access to all data. The collection of data by Facebook is unhindered by the privacy settings of an user. Our goal is to provide people a method to assert a desire that certain data not to be collected by Facebook at all. This is only possible if the person is able to clearly identify and refuse the collection of specific information. As privacy policy acts as a binding legal document, collecting data explicitly denied could be would in violation of privacy law. Regardless of the regulatory issues; the ability to identify data flows is a critical component of individual control over data.

4 Framework Development

The first step to development following the literature review process was to study the different sections of Facebook's Data Policy and synthesize a unique model which differentiates between the services and the extent of collected data. We do this by studying Facebook's privacy policy and then iterating through the following steps:

1. Develop sections for classification derived from the Data Policy.
2. Map them into the classifications of various services.
3. Determine if the services' data compilations are covered by the sections identified in the second step.
4. Develop the modular sections of the policy based on the mapping.
5. Validate the usability of the modular policy by conducting in-person pilot interviews .

In the next section we describe the results from the analysis described above. We summarize the relevant sections, which clearly map to Solove's previous taxonomy [35].

5 Analysis and Results

The different sections that were the result of the iterative process above mentioned can be broadly classified into the following categories:

- Service offered
- Data collected (including sub-section permissions like microphone, camera, etc.)
- Data use or purpose of compilation
- Default consent setting
- Ability to modify the setting in the future
- Data storage
- Duration of storage/deletion policies

We include significant details from the actual Data Policy which ensures that most of the legal statements are included in a simple, lucid manner. Solove identified collection, processing, sharing, and dissemination are reflected in all but the first item above. His final component is *invasion* which includes intrusion and decisional interference. The minimization of these components is the core goal of this project.

One of the key takeaways while designing the modular policy framework while enumerating the different sections of the policy reveal many gaps in the actual policy statement. For example, it was not clear if certain services like *Messenger* and *Advertisements* stored user information for a longer time than necessary. Also, how such information was stored was not mentioned. This leaves gaps in the model which can be seen in Section 4. Additionally, it further reaffirms privacy policies have '*vague statements*' as described by Reidenberg et al. [32].

Find Friends Service

Data Collected

- User contact information
- Your network contact information
- Any other contact information from mail lists that you may choose to upload
- Contact information which is uploaded, synced or imported (like an address book) on any device using the service

Data Usage

- Make suggestions (People You May Know)

Data Storage

- As long as necessary for an active account

Facebook states that this data is compiled 'as long as necessary for an active account'. However, this assertion is over-ridden by the policy of Facebook, 'Information others share about you will not be deleted even if you delete your account'.

Posts (Including photos and videos)

Data Collected

- Data provided as part of post
- Any meta-data present in the photos/videos

Data Usage

- Make suggestions (tags), personalized content

Data Storage

- Removed content may persist in backup copies for reasonable period of time (will not be available to others)
- IP license ends when data deleted unless it has been share with others and they have not deleted it
- As long as necessary for an active account
- Information others share about you will not be deleted even if you delete your account

Country Specific Policy

- You consent to having your personal data transferred to and processed in the US
- Public posts are accessible to everyone on and off Facebook
- For IP content, you grant us royalty-free worldwide license that you post on or in connection with Facebook

Again Facebook states that this data is compiled 'as long as necessary for an active account'. And again, this assertion is over-ridden by the policy of Facebook, 'Information others share about you will not be deleted even if you delete your account'.

Messenger

Data Collected

- Any data sent through the service including the text, files(audio/video/other file types) will be collected.

Data Usage

- Make suggestions to the user based on the conversations.
- Identified suggestions include for creating a meeting plan or for using Facebook Payments

Data Storage

- As long as necessary for an active account.
- Messages, actions, and conversations would persist on the other person's account even if the participant deactivates account.

Pages

Data Collected

- Any user activity with a page, including likes, comments and sharing.

Data Usage

- Ads, marketing
- Location and local events

Data Storage

- As long as necessary for an active account. Message conversations would persist on the other person's account even if the user deactivates account.
- All information shared on public pages are public

Events and Check-ins

Data Collected

- Location (using IP address, GPS and location services, location from profile)

Data Usage

- Deliver services, ads
- Identify local events

Data Storage

- As long as necessary for an active account

Games

Data Collected

- Public profile (username, age range, country, language, friend list and any other information you share with them)
- User activities in game or comments on shared links on their website or Facebook

Data Usage

- Ads, marketing
- Delivery services

Data Storage

- As long as necessary for an active account. Information others share about you will not be deleted even if you delete your account.

Facebook Payments

Data Collected

- Payment information (debit or credit card number, other card information).
- Other account and authentication information (like a payment gateway).
- Billing and shipping details.

Data Usage

- Delivery services

Data Storage

- As long as necessary for an active account.

Again the larger policy indicates that information others shared by others will not be deleted, even if the person's account is deleted. There is also a generic nearly infinitely expandable statement, "May be accessed, processed and retained for an extended period of time for legal and non-legal purposes".

6 Experiment Design

The most commonly used method for evaluating people's privacy concerns is through the work of Malhotra et al.'s Internet users' information privacy concerns (IUIPC): The construct, the scale, and a causal model [25]. Building upon this we asked the following questions:

Do people actively care about their privacy?

Have they ever rejected a website just because of privacy concerns and because they collected a lot of data?

In evaluating the policy proposal we sought to answer questions unique to this particular research, specifically:

How do we design the modular policy in a way that fits into an average user's perspective?

Do privacy preferences for modularity vary between experts and non-experts?

We distinguish between experts and non-experts based on (i) Occupation or Study Major (ii) Experience working in privacy/security in development or technical knowledge of privacy (iii) Experience using the platform or similar platforms (iv) Experience reading privacy policies These questions are grounded in the general measurement for security and computer expertise developed by Rajivan et al. [31]. The decision to change the questions was grounded in the use of the classic convenience sample; university students. As these were students some of the questions were not applicable in terms of differentiating levels of expertise, as they all were required to comply with University security policies. In addition, university students have a well-defined curriculum which defines their requisite knowledge base. Essentially, in studies in broader populations the defining question of a participants' chosen major is either inapplicable or made meaningless through life experience.

6.1 Recruitment

We recruited seven participants for our pilot study; 3 of whom were female and 4 were male in the age group of 18-25 years. All of the participants were Facebook users with different levels of technical expertise. The experiment consisted of a two-phase semi-structured interview for a group of undergraduate and graduate students at Indiana University across different majors and specializations. In order to indicate a diverse group of technical and non-technical people of Facebook, we recruited participants with the different majors of participants as mentioned in Table 1. Note that P1, P2, ..., P7 indicates the different participants who have taken part in the experiment. None of the participants had former knowledge or background in security or privacy during their coursework at the university.

P1	Music Performance
P2	Ballet
P3	Design
P4	Computer Science
P5	Music
P6	Psychology
P7	Data Science

Table 1. Majors of different Participants

6.2 Incentive

Since this was a pilot study, there were no monetary incentives for the participants to take part in the study. However, as the interviewees voluntarily participated in the interview, we can consider their responses to be factually accurate to the best of their knowledge.

6.3 Interview Questions

The model was tested through a two-part interview protocol with 7 participants, all of whom had varied experiences with social media and used Facebook. In the first half of the interview, each participant was familiarized with Facebook's existing data policy and asked about their current privacy choices within that policy. They were also asked about their familiarity with Facebook's *Privacy Check* feature to gauge how much the participants were actively managing their privacy. Table 2 shows the list of questions for the first phase of the interview.

1. Do you typically read Facebook's 'Data Policy'?
2. If yes, then are you concerned about specific sections?
3. Do you read privacy policies for any other website specifically?
4. What are your thoughts on Facebook's collection of your personal data?
5. How frequently do you use the <i>Privacy Check</i> feature?

Table 2. Facebook Data Policy Interview Questions

After the interviewees responded to the first phase of the interview, the modular policy, based on the description in Section 4 was shown and explained to them. As mentioned before, the modular policy had two options. The first was to select all the different parts of the policy. The second option was to select only the parts of the policy for selective services which they voluntarily allowed data to be collected for. Table 3 lists the questions that were asked to the participants. After collecting participant feedback from the the two part interview process, we collected some demographic information like *Major of Study*, *Age* and *Familiarity with technology or privacy in specific* with the follow-up questions listed in Table 4.

1. Comparing the actual Data Policy and the current that you see, what are your thoughts?
2. Does it give you a clearer idea of the information that is collected?
3. Are there specific services you are willing to forego to preserve your data from being collected?
4. What are your thoughts on Facebook's collection of your personal data?
5. Does it increase your trust in the organization?
6. Did it take you less or more time to read the current policy compared to the actual Data Policy?
7. Did this model draw your attention to the privacy policy in particular?

Table 3. Modular Privacy Policy Interview

1. What is your major?
2. What is your age?
3. Do you read privacy policies for any other website specifically?
4. What are your thoughts on Facebook's collection of your personal data?
5. How frequently do you use the <i>Privacy Check</i> feature?

Table 4. Demographic Interview Questions

6.4 Interview Findings

At the outset, we found that people with a technical background had more concerns about their privacy as indicated by participants P4 and P7 because they were more likely to be aware of the *Privacy Check* feature and regularly updated it. Overall usage of the feature was rare. This indicates that the participants did not spend much time looking up their privacy settings. The other key findings from the first half of the interview are summarized below.

Participants did not pay attention to privacy policies, reifying the results of Schaub et al [34]. However, people were willing to read the policies if they were directed to them, especially when a website collected sensitive information, such as credit card details. Participants were concerned about their data only when financial or other information they perceived as sensitive was collected from them. They did not perceive risks of other data being collected not directly linked to the service. Participants were aware that their data was being collected, and were even linked to other websites due to the third party access strategies.

Most participants expressed that they intentionally refrained from divulging personal information on Facebook or other social media websites in the first place. For example, interviewee P5 says, "*I know they are (collecting data). So I don't post anything that compromises my safety.*". Participant P5 also curated posts and information on the Facebook profile page specifically so that companies are able to search and communicate. Such statements indicate lack of trust on the organization by its users, which should not be the business model of any organization.

6.5 Interview Discussion

Interviews in the second phase were composed of questions addressing participant interaction after having been shown the modular privacy policy. Most participants indicated that they were more likely to attend to the modular privacy policy over the current data policy, even though they were not used to reading them. To support this claim, they said

that since the new form of the policy was *more visually appealing* due to the segregation compared to a conventional policy model due to the presence of bullet points and overall structure.

Participants also stated how they liked having the choice to opt out of features when they were not interested in a service. Most participants also were ready to use different services even though they were clearly not comfortable with the policy corresponding to that service. They also showed concerns about photo tagging and messaging platform of Facebook but were happy to use them anyway. They did demonstrate a basic awareness about the data being collected by Facebook from them citing various news articles. This aligns with previous research by Good et al., who found that individuals were more accepting of User License Agreement (EULA) terms if these were made clear before installation [18].

Six of the seven participants mentioned that their trust in an organization would increase if they were presented with a modular privacy model as it conveys transparency. Few participants expressed the opinion that the modular privacy model is more clear and condensed, they might take longer to read it as they will be *“actually paying attention to it”*.

One participant preferred controlling their own behaviour rather than turning off the service. *“I don’t want sensitive messages to be collected but if that means forgoing the service, then I just won’t send such messages”*. One participant wondered if the entire privacy policy of Facebook can be condensed into our modular privacy model without loss of any information. The problems of creating site-wide consistent information in P3P suggest that this is a nearly intractable problem.

7 Discussion

By converting a privacy policy into a summary we intended to build on other efforts, such as the IoT privacy policy proposals [4, 19, 20] that are based on the nutrition label approaches [21]. On the occasion that privacy policies are read, people usually go through them briefly and hence take a short time to read them. However, a modular privacy policy is intended to enable people to better evaluate the trade-offs in terms of privacy or benefit for each service. Such transparency and informed decision-making have long been identified as policy goals.

A few participants suggested that having a modular privacy policy creates risk awareness, making the platform less appalling. That a more clear and detailed understanding of data collection from the framework could be seen as a negative. In fact, an early study of privacy policies before the myriad social networks merged into the few remaining by Bonneau and Preibusch found that social networks which provided privacy information were associated with greater privacy risk than those that were more opaque. They suggested that such transparency increased awareness only for those sites with visible privacy policies [5]. We agree with their work that uniformity is needed, and acknowledge the implications of their results for this line of research.

8 Limitations

The core goal of breaking down policies is to inform and enable more granular decisions is counter to the more popular approaches in current privacy studies. Specifically, the use of big data and machine learning are increasingly proposed as methods to remove human decision making. Instead of the human in the loop intelligent agents are used to automate decision-making. The goal here is to support decision-making at the risk of creating something like the much decried GDPR cookie storm.

Our study included only 7 participants as a part of the pilot study. Future work will use these qualitative results to inform an empirical evaluation, as described. Even though the participants were from diverse backgrounds as well as including men and women, their ages and levels of computing expertise were similar. Other factors that we plan to explore in quantitative research includes the effects of expertise, framing, and ease of use of the modular policies on the selection of services, apps, and information sharing on Facebook. The most basic limitation on use of this for social networks is that there is an over-riding policy allowing unconstrained use with no deletion on Facebook. Conversely, as illustrated by the introduction of Libra, individuals may choose not to use all services provided by Facebook.

The modular approach also needs further investigation for comparisons of IoT privacy policies to provide a general and adaptable format. IoT privacy policies include device policies as well as app policies, and the combination of different devices may create unpredictable interactions.

9 Conclusion

The modular privacy policy framework proposed in this paper provided an option to take control of one's privacy by selectively agreeing to only sections of the services offered. These sections correspond to specific modular privacy policies.

On the positive note, when participants were provided with a modular framework their level of concern increased as the data compilation was made clear along with the related policies and data use. Our goal is to increase risk awareness about data collection, with people taking more control of their privacy when given clear communication. Our participants were able to relate these services to their associated data compilation. This allowed them to take a conscious informed risk/benefit by either forgoing the service for privacy or choosing the service and accepting the corresponding use of data. Furthermore, they stated that their trust in an organization would increase if it implemented the modular privacy policy framework. There was a desire to understand which services collect what kind of data.

10 ACKNOWLEDGEMENT

This research was supported in part by the National Science Foundation under CNS 1565375, Cisco Research Support, and the Comcast Innovation Fund. We would like to acknowledge the guidance of Dr. Sameer Patil and assistance of Kaushik Srinivasan in the initial genesis of this work. Any opinions, findings, and conclusions or recommendations expressed in this material are those of the author(s) and do not necessarily reflect the views of the the US Government, the National Science Foundation, Cisco, Comcast, nor Indiana University.

References

1. Number of monthly active facebook users worldwide as of 2nd quarter 2019 (in millions). <https://www.statista.com/statistics/264810/number-of-monthly-active-facebook-users-worldwide/>, August 2019.
2. Alessandro Acquisti and Jens Grossklags. Privacy and rationality in individual decision making. *IEEE Security & Privacy*, 3(1):26–33, 2005.
3. Oliver Berthold and Marit Köhnopp. Identity management based on p3p. In *Designing Privacy Enhancing Technologies*, pages 141–160. Springer, 2001.
4. JM Blythe and SD Johnson. The Consumer Security Index for IoT: A protocol for developing an index to improve consumer decision making and to incentivize greater security provision in iot devices. 2018.
5. Joseph Bonneau and Sören Preibusch. The privacy jungle: On the market for data protection in social networks. In *Economics of information security and privacy*, pages 121–167. Springer, 2010.
6. L Jean Camp. Designing for trust. In *Workshop on Deception, Fraud and Trust in Agent Societies*, pages 15–29. Springer, 2002.
7. L Jean Camp, Jayati Dev, Sanchari Das, and Yasmeen Rashidi. Personalized whatsapp privacy: Demographic and cultural influences on indian and saudi users. *Available at SSRN*, 2019.
8. L Jean Camp and Carlos A Osorio. Privacy-enhancing technologies for internet commerce. *Trust in the Network Economy*, pages 317–331, 2003.
9. Fred H Cate. The limits of notice and choice. *IEEE Security & Privacy*, 8(2), 2010.
10. Ibrahim Cingil, Asuman Dogac, and Ayca Azgin. A broader approach to personalization. *Communications of the ACM*, 43(8):136–141, 2000.
11. Lorrie Cranor. *Web Privacy With P3P*. ” O’Reilly Media, Inc.”, 2002.
12. Lorrie Faith Cranor, Praveen Guduru, and Manjula Arjula. User interfaces for privacy agents. *ACM Transactions on Computer-Human Interaction (TOCHI)*, 13(2):135–178, 2006.
13. Sanchari Das, Jayati Dev, and Kaushik Srinivasan. Modularity is the key: A new approach to social media privacy policies. In *Proceedings of the 7th Mexican Conference on Human-Computer Interaction*, page 13. ACM, 2018.
14. Bernhard Debatin, Jennette P Lovejoy, Ann-Kathrin Horn, and Brittany N Hughes. Facebook and online privacy: Attitudes, behaviors, and unintended consequences. *Journal of Computer-Mediated Communication*, 15(1):83–108, 2009.
15. Jayati Dev, Sanchari Das, and L Jean Camp. Privacy practices, preferences, and compunctions: Whatsapp users in india. In *Proceedings of the Twelfth International Symposium on Human Aspects of Information Security & Assurance (HAISA 2018)*, page 135. Lulu.com, 2018.
16. Adrienne Porter Felt, Kate Greenwood, and David Wagner. The effectiveness of application permissions. In *Proceedings of the 2nd USENIX conference on Web application development*, pages 7–7, 2011.
17. Martin Fishbein and Icek Ajzen. Belief, attitude, intention, and behavior: An introduction to theory and research. 1977.

18. Nathaniel Good, Rachna Dhamija, Jens Grossklags, David Thaw, Steven Aronowitz, Deirdre Mulligan, and Joseph Konstan. Stopping spyware at the gate: A user study of privacy, notice and spyware. In *Proceedings of the 2005 symposium on Usable privacy and security*, pages 43–52. ACM, 2005.
19. Shakhthidhar Reddy Gopavaram, Jayati Dev, Sanchari Das, and Jean Camp. Iotmarketplace: Informing purchase decisions with risk communication.
20. Christina Hochleitner, Cornelia Graf, Dominik Unger, Manfred Tscheligi, and ICTS Center. Making devices trustworthy: Security and trust feedback in the Internet of Things. In *Fourth International Workshop on Security and Privacy in Spontaneous Interaction and Mobile Phone Use (IWSSI/SPMU)*, 2012.
21. Patrick Gage Kelley, Joanna Bresee, Lorrie Faith Cranor, and Robert W Reeder. A nutrition label for privacy. In *Proceedings of the 5th Symposium on Usable Privacy and Security*, page 4. ACM, 2009.
22. Brian Kint. 5 ways in which your company’s privacy policy is insufficient. <http://cyberlawmonitor.com/2019/04/05/5-ways-in-which-your-companys-privacy-policy-is-insufficient/>, May 2019.
23. Bert-Jaap Koops. The trouble with european data protection law. *International Data Privacy Law*, 4(4):250–261, 2014.
24. Kalev Leetaru. Social media companies collect so much data even they can’t remember all the ways they surveil us. <https://www.forbes.com/sites/kalevleetaru/2018/10/25/social-media-companies-collect-so-much-data-even-they-cant-remember-all-the-ways-they-surveil-us/525b16c57d0b>, October 2018.
25. Naresh K Malhotra, Sung S Kim, and James Agarwal. Internet users’ information privacy concerns (iuipc): The construct, the scale, and a causal model. *Information systems research*, 15(4):336–355, 2004.
26. Ayan Kanti Mandal, Yuan Xie, David Luke Richardson, Cherry Mangat, Nam Huy Bui, Derek Joseph Halliday, and Arun-sunai Anbukarasi Anbalagapandian. Mobile Communication Device Display with Graphical User Interface Comprising Security and Privacy Advisor Screens, January 2015. US Patent D720,766.
27. Alessandro Mantelero. The future of consumer data protection in the eu re-thinking the notice and consent paradigm in the new era of predictive analytics. *Computer Law & Security Review*, 30(6):643–660, 2014.
28. Aleecia M McDonald and Lorrie Faith Cranor. The cost of reading privacy policies. *ISJLP*, 4:543, 2008.
29. Don Norman. *The Design of Everyday Things*. Basic Books, 2013.
30. Ehimare Okoyomon, Nikita Samarin, Primal Wijesekera, Amit Elazari Bar On, Narseo Vallina-Rodriguez, Irwin Reyes, Álvaro Feal, and Serge Egelman. On the ridiculousness of notice and consent: Contradictions in app privacy policies. 2019.
31. Prashanth Rajivan and Jean Camp. Influence of privacy attitude and privacy cue framing on android app choices. In *Twelfth Symposium on Usable Privacy and Security ({SOUPS} 2016)*, 2016.
32. Joel R Reidenberg, Jaspreet Bhatia, Travis D Breaux, and Thomas B Norton. Ambiguity in privacy policies and the impact of regulation. *The Journal of Legal Studies*, 45(S2):S163–S190, 2016.
33. Florian Schaub. Nobody reads privacy policies heres how to fix that. <https://news.engin.umich.edu/2017/10/nobody-reads-privacy-policies-heres-how-to-fix-that/>, October 2017. (Accessed on 12/12/2017).
34. Florian Schaub, Rebecca Balebako, and Lorrie Faith Cranor. Designing effective privacy notices and controls. *IEEE Internet Computing*, 21(3):70–77, 2017.
35. Daniel J Solove. A taxonomy of privacy. *U. Pa. L. Rev.*, 154:477, 2005.
36. Daniel J Solove. Introduction: Privacy self-management and the consent dilemma. *Harv. L. Rev.*, 126:1880, 2012.
37. Katy Steinmetz. Google, facebook, twitter privacy policies: Ranked by readability. <http://time.com/3986016/google-facebook-twitter-privacy-policies/>, August 2015. (Accessed on 12/11/2017).
38. William H Stufflebeam, Annie I Antón, Qingfeng He, and Neha Jain. Specifying privacy policies with p3p and epal: Lessons learned. In *Proceedings of the 2004 ACM workshop on Privacy in the electronic society*, pages 35–35. ACM, 2004.
39. Daniel Susser. Notice after notice-and-consent: Why privacy disclosures are valuable even if consent frameworks arent. *Journal of Information Policy*, 2019.
40. Maximilian Teltzrow and Alfred Kobsa. Impacts of User Privacy Preferences on Personalized Systems. In *Designing personalized User Experiences in eCommerce*, pages 315–332. Springer, 2004.
41. Craig Timberg and Elizabeth Dwoskin. How years of privacy controversies finally caught up with facebook. <https://www.washingtonpost.com/technology/2018/07/26/how-years-privacy-controversies-finally-caught-up-with-facebook/?noredirect=on>, July 2018. (Accessed on 08/07/2019).
42. George OM Yee. A privacy controller approach for privacy protection in web services. In *Proceedings of the 2007 ACM Workshop on Secure Web Services*, pages 44–51. ACM, 2007.
43. Ting Yu, Ninghui Li, and Annie I Antón. A formal semantics for p3p. In *Proceedings of the 2004 workshop on Secure web service*, pages 1–8. ACM, 2004.
44. Hengshu Zhu, Hui Xiong, Yong Ge, and Enhong Chen. Mobile App Recommendations with Security and Privacy Awareness. In *Proceedings of the 20th ACM SIGKDD International Conference on Knowledge Discovery and Data Mining*, pages 951–960. ACM, 2014.